

주식고수 공격2

```
.rdata:00007FF7CD7F44DF align 20h
.rdata:00007FF7CD7F44E0 ; char asc_7FF7CD7F44E0[12]
.rdata:00007FF7CD7F44E0 asc_7FF7CD7F44E0 db '종목명',0 ; DATA XREF: sub_7FF7CD7E8CE0+2C1fo
.rdata:00007FF7CD7F44E0 ; sub_7FF7CD7E8CE0+87Dfo
.rdata:00007FF7CD7F44EA db 0
.rdata:00007FF7CD7F44EB db 0
.rdata:00007FF7CD7F44EC ; char asc_7FF7CD7F44EC[8]
.rdata:00007FF7CD7F44EC asc_7FF7CD7F44EC db '티커',0 ; DATA XREF: sub_7FF7CD7E8CE0+2D6fo
.rdata:00007FF7CD7F44EC ; sub_7FF7CD7E8CE0+892fo
.rdata:00007FF7CD7F44F3 db 0
.rdata:00007FF7CD7F44F4 ; char asc_7FF7CD7F44F4[12]
.rdata:00007FF7CD7F44F4 asc_7FF7CD7F44F4 db '가격',0 ; DATA XREF: sub_7FF7CD7E8CE0+2EBfo
.rdata:00007FF7CD7F44FB db 0
.rdata:00007FF7CD7F44FC db 0
```

데이터 영역에서 빨간색 깨진 문자열을 복원하니 종목명 등 변수가 나옴 그 변수가 나온 곳으로 이동하니

```
400 v44 = nullptr;
401 }
402 *(_QWORD *)(a1 + 96) = v44;
403 QTableWidgetItem::setColumnCount(v44, 6);
404 v45 = *(_QWORD *)(a1 + 96);
405 QString::QString((QString *)v93, "종목명");
406 QString::QString((QString *)v94, "티커");
407 QString::QString((QString *)v95, "보유수량");
408 QString::QString((QString *)v96, "현재가");
409 QString::QString((QString *)v97, "평단가");
410 QString::QString((QString *)v98, "평가손익(%)");
411 v46 = QArrayData::allocate(v66, 24, 8, 6, 1);
412 v67 = (const char *)v66[0];
413 v68 = v46;
414 v69 = 0;
415 if ( !v46 )
416 {
417     qBadAlloc();
418     debugbreak();
419 }
```

이렇게 뭔가의 ui를 설정하고 있었다 따라서 혹시 이벤트 처리도 있지 않을까 해서 connect를 쳐봤더니

```
00078D8B jmp 7FF7CD7E8CE0:253 (7FF7CD7E8D8B)
*(_QWORD *)(&v45 + 8) = 82077FF7CD7E8D8B?
*(_QWORD *)v45 = 7:
{
if ( v45 )
v45 = (const char *)v45?
v45 = 82077FF7CD7E8D8B(0x500)?
v45 = HIDWORD(v45)?
v45 = 0?
v45 = 0x7FF7CD7E8D8B:0x7FF7CD7E8D8B?
HIDWORD(v45) = HIDWORD(v45)?
DWORD(v45) = 0?
*(_QWORD *)v45 = 82077FF7CD7E8D8B?
0x7FF7CD7E8D8B:0x7FF7CD7E8D8B?
0x7FF7CD7E8D8B:0x7FF7CD7E8D8B?
}
v45 = 0?
```

이렇게 뭔가 서버에게 내가 보내는 정보와 관련된 함수를 찾을 수 있었다. 함수의 내부로 들어가 보니

```
IDA View... Pseudocode... Stack of sub_140018C... Hex View
81 if ( (unsigned __int64)v8[7] > 0xF )
82     v10 = (_QWORD *)v10;
83     v12 = v8[6];
84     if ( v11 > 4 )
85         v12 = 4;
86     v13 = memcmp(v10, "cash", v12);
87     if ( v13 )
88     {
89         if ( v13 < 0 )
90             goto LABEL_25;
91     }
92     else if ( v11 < 4 )
93     {
94 LABEL_25:
95         v8 = (__int64 *)v8[2];
96         goto LABEL_14;
97     }
98     v9 = v8;
99     v8 = (__int64 *)v8;
100 LABEL_14:
101     if ( *((_BYTE *)v8 + 25) )
102     {
```

```
IDA View... Pseudocode... Stack of sub_140018C... Hex View... Local Typ...
109 if ( (unsigned __int64)v9[7] > 0xF )
110     v14 = (_QWORD *)v14;
111     v16 = v9[6];
112     if ( v15 > 4 )
113         v16 = 4;
114     v17 = memcmp(v14, "cash", v16);
115     if ( v17 )
116     {
117         if ( v17 <= 0 )
118             goto LABEL_28;
119 LABEL_27:
120         v9 = v7;
121     }
122     else if ( v15 > 4 )
123     {
124         goto LABEL_27;
125     }
126 LABEL_28:
127     if ( v9 != *v6 )
128     {
129         v22 = 0;
130         sub_7FF7CD7E6E90(v19, "cash", &v22);
131         sub_7FF7CD7EBAF0(a1);
```

뭔가 구조상 내가 주식을 매수하거나 매도한 후에 내 잔액 현금을 갱신하는 함수인 듯했다. 거기서 직접 내가 매수하려는 id의 가격 등을 확인하는 곳으로 가보니

```
46 v26 = 15;
47 LOBYTE(v24) = 0;
48 if ( !(unsigned __int8)sub_7FF7CD7F4D90(
49     *(_QWORD *) (a1 + 40),
50     *(_DWORD *) (a1 + 48),
51     v2,
52     (int)v4,
53     (__int64)v19,
54     (__int64)&v24) )
55 {
56     v5 = QString::fromStdString(v21, &v24);
57     QString::QString((QString *)v23, byte_7FF7CD7F4690);
58     QMessageBox::warning(a1, v23, v5, 1024, 0);
```

```

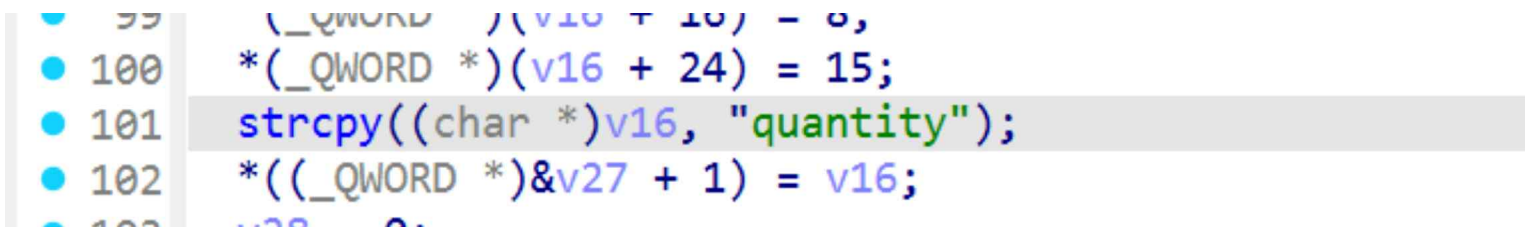
5  *(_QWORD *)v13 = 0;
7  *(_QWORD *)(v13 + 16) = 8;
3  *(_QWORD *)(v13 + 24) = 15;
9  strcpy((char *)v13, "stock_id");
9  *(_QWORD *)&v31 + 1 = v13;
1  v32 = 0;
2  v33 = 0u;
3  sub_7FF7CD7DDBD0((char *)&v33 + 8, 0);
4  LOBYTE(v33) = 5;
5  *(_QWORD *)&v33 + 1 = v7;
5  v34 = 0;
7  *(_QWORD *)&v24 = &v31;
3  *(_QWORD *)&v24 + 1 = &v35;
9  LOBYTE(v14) = 2;
9  LOBYTE(v15) = 1;
1  sub_7FF7CD7DA6F0(v43, &v24, v15, v14);
2  v44 = 0;
3  *(_QWORD *)&v24 = &v27;
v27 = 0;

19  *(_QWORD *)(v16 + 16) = 8;
10  *(_QWORD *)(v16 + 24) = 15;
11  strcpy((char *)v16, "quantity");
12  *(_QWORD *)&v27 + 1 = v16;
13  v28 = 0;
14  v29 = 0u;
15  sub_7FF7CD7DDBD0((char *)&v29 + 8, 0);
16  LOBYTE(v29) = 5;
17  *(_QWORD *)&v29 + 1 = v6;
18  v30 = 0;
19  *(_QWORD *)&v24 = &v27;
0  *(_QWORD *)&v24 + 1 = &v31;
.1  LOBYTE(v17) = 2;
.2  LOBYTE(v18) = 1;
.3  sub_7FF7CD7DA6F0(v45, &v24, v18, v17);
.4  v46 = 0;
5  *(_QWORD *)&v24 = v41;
6  *(_QWORD *)&v24 + 1 = &v47;
.7  LOBYTE(v19) = 2;
.8  LOBYTE(v20) = 1;
9  sub_7FF7CD7DA6F0(v39, &v24, v20, v19);
sub_7FF7CD7E00A0(v41, v24, 2, sub_7FF7CD7DB250);
0000CB0E|sub_7FF7CD7DD490:115 (7FF7CD7DD70E)

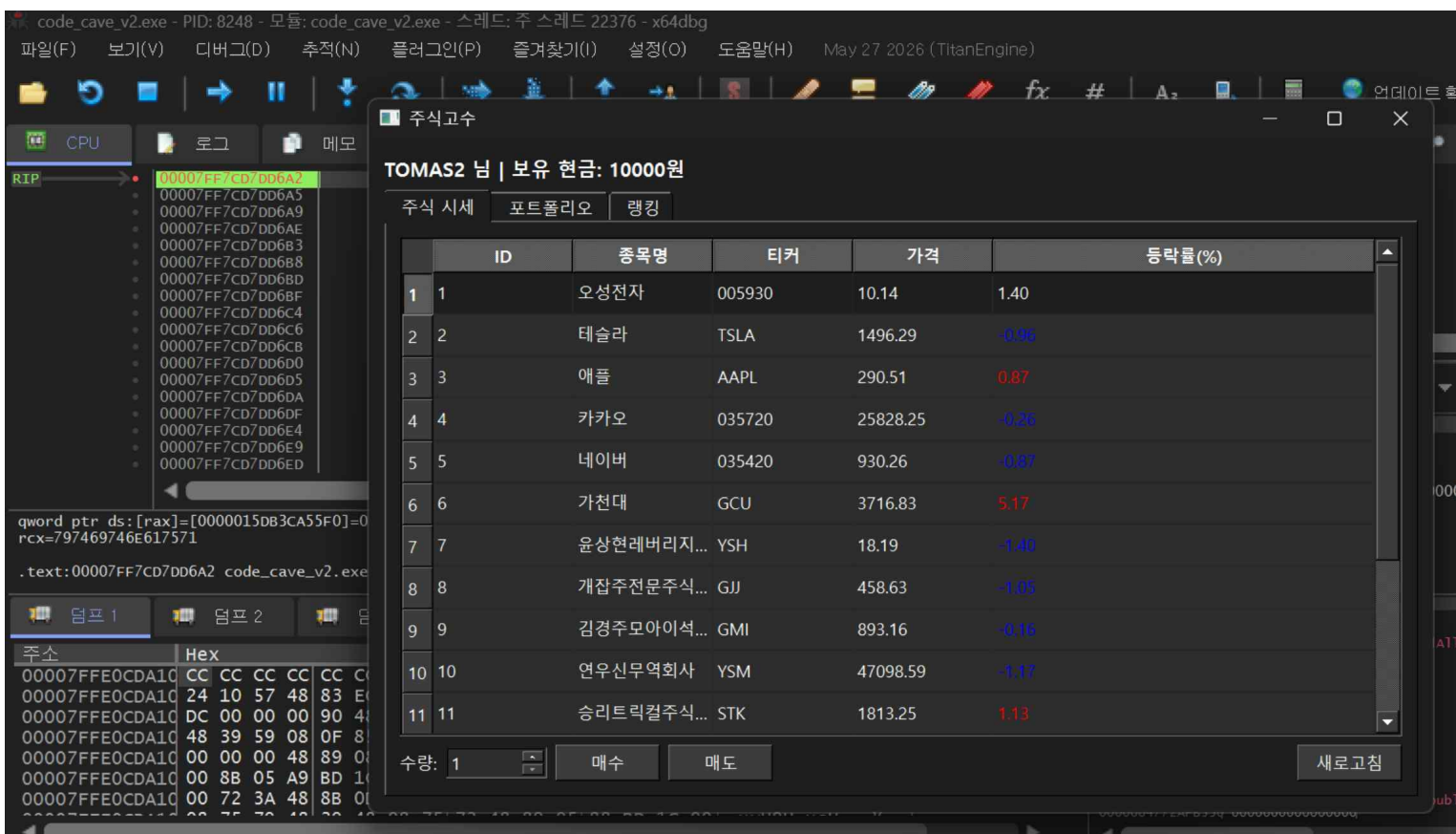
124  v44 = 0;
125  v25 = 4;
126  v26 = 15;
127  strcpy((char *)&v24, "/buy");
128  v21 = sub_7FF7CD7DE730(a1, (unsigned int)&v24, (unsigned int)v39, a5, a6);
129  if ( v26 > 0xF )
130  {
131      v22 = (void *)v24;
132      if ( v26 + 1 >= 0x1000 )
133      {
134          if ( (unsigned int64)(v24 - *(_QWORD *)(v24 - 8) - 8) > 0x1F )

```

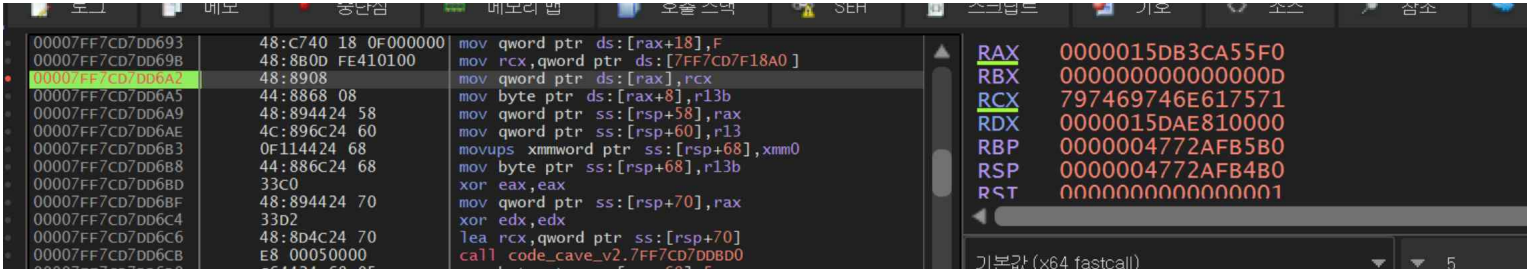
내가 살 주식의 종류와 개수를 서버에 보내는 함수 같았다. 여기서 나는 보내는 수량을 음수로 만들어보기로 결정했다. 그러기 위해서는 새 계정 TOMAS2를 만들고 로그인을 해서



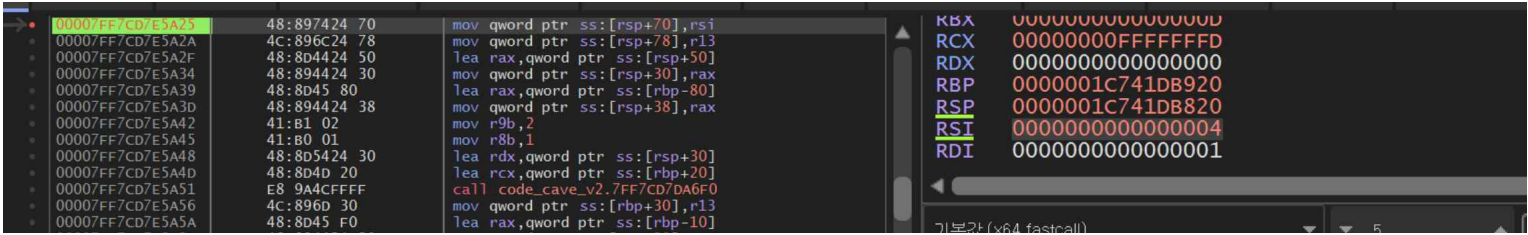
ida코드의 이 부분의 주소를 xdbg에서 중단점을 설정하고 실행하니



실제 매스 버튼을 클릭하자 중단점의 위치로 이동했다 이를 통해서 내 가설이 맞았다는 걸 알 수 있다. 그 다음엔



그 주변을 xdbg64로 정적 분석해 보니 여기 지점에서 내 매도 개수를 저장한다는 걸 파악을 했다. 그리고 그 값을 음수로 바꾸어 보았더니 다음과 같이 났다.



TOMAS2 님 | 보유 현금: 9959원

주식 시세 포트폴리오 랭킹

	ID	종목명	티커	가격	등락률(%)
1	15	X	GHM	10.00	0.00
2	1	삼성전자	005930	12.46	0.87
3	2	테슬라	TSLA	242.00	-1.12
4	3	애플	AAPL	130.00	-0.15
5	4	카카오	035720	45.00	-0.22
6	5	네이버	035560	240.00	-0.42
7	6	가천대	GCU	8138.45	-1.01
8	7	윤상현레버리지...	YSH	18.47	1.52
9	8	개잡주전문주식...	GJJ	436.20	0.11
10	9	김경주모아이석...	GMI	665.22	-3.52
11	10	연우신무역회사	YSM	37979.85	-1.07

수량: 4 매수 매도 새로고침

매도 실패

수량은 1 이상이어야 합니다

OK

그러면 이번엔 내가 가지고 있는 수량보다 더 많이 매도를 해보도록 하자

TOMAS2 님 | 보유 현금: 9959원

주식 시세 포트폴리오 랭킹

	종목명	티커	보유수량	현재가	평단가	평가손익(%)
1	삼성전자	005930	4	22.66	10.35	118.86

현재 나는 오성전자의 주식을 4개 가지고 있지만 100개를 팔아보려고 한다 이를 위해 rsi레지스터를 100개로 바꾸고 f8을 눌러 막히는지 아니면 되는지 확인하고 막히면 막힌 지점의 비교구문을 바꾸려고 한다.

```

RBP 000000B70F59B6F0
RSP 000000B70F59B5F0
RST 0000000000000064 'd'
RDI 0000000000000001

```

이렇게 rsi를 100으로 바꿔주고 진행하고

```

00007FF7CD7EA4F4 48:8D4D A7 lea rcx,qword ptr ss:[rbp-59]
00007FF7CD7EA4F5 84C0 test al,al
00007FF7CD7EA4F6 75 55 jne code_cave_v2.7FF7CD7EA551
00007FF7CD7EA4F7 48:8D55 E7 lea rdx,qword ptr ss:[rbp-19]
00007FF7CD7EA4F8 FF15 E25C0000 call qword ptr ds:[<public: static class QString
00007FF7CD7EA4F9 48:8BD8 mov rbx,rcx
00007FF7CD7EA4FA 48:8D15 F0A10000 lea rdx,qword ptr ds:[7FF7CD7F4700]
00007FF7CD7EA4FB 48:8D4D C7 lea rcx,qword ptr ss:[rbp-39]
00007FF7CD7EA4FC FF15 D65C0000 call qword ptr ds:[<public: __cdecl QStr
00007FF7CD7EA4FD 90 nop
00007FF7CD7EA4FE 44:897C24 20 mov dword ptr ss:[rsp+20],r15d
RAX 0000000000000001
RBX 0000000000000002
RCX 000000B70F59B800 &"カカカカカ"
RDX 0000024EDA590000
RBP 000000B70F59B859
RSP 000000B70F59B7C0
RST 0000000000000000

```

test al에서 rax의 값을 1로 바꿔주면

TOMAS2 님 | 보유 현금: 9955원

주식 시세

포트폴리오

랭킹

	ID	종목명	티커	가격	등락률(%)
5	9	김경주모아이석...	GMI	585.24	-0.65
6	10	연우신무역회사	YSM	19021.20	-1.52
7	11	승리트릭컬주식...	STK		
8	12	고한민성장촉진...	KSJ		
9	13	이상어 ...	LSA		
10	14	엔비디아	NVA		
11	15	X	GHM	21.05	1.70
12	1	오성전자	005930	11.50	1.10
13	2	테슬라	TSLA	613.30	-0.87
14	3	애플	AAPL	895.82	-1.24
15	4	카카오	035720	72059.74	-1.67

수량: 2

매수

매도

새로고침

매도 완료

매도가 완료되었습니다.

OK

이렇게 매도가 완료되었다고는 뜨지만 실제로는 100개가 아닌 2개만 매도가 되었다.여기서 더 나아가면 실제 서버를 해킹해야 되서 여기까지만 리버싱을 진행했다.

